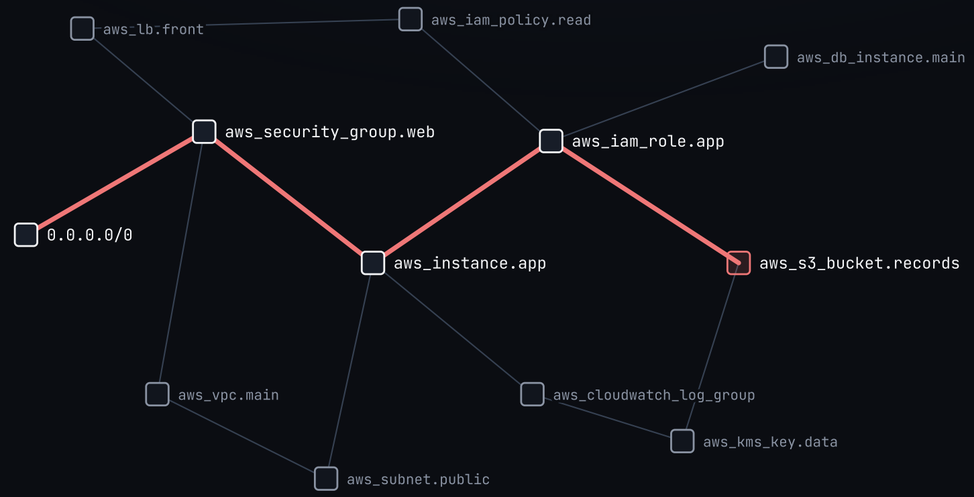
# Explainable and Context-Aware AWS Cloud Misconfiguration and *Attack-Path* Risk Analyzer

A Terraform-Based Pre-Deployment Analysis with Optional Read-Only AWS Validation





PRESENTED BY

**Muhammad Akif Zafran Bin Mohd Zulkifly** · 23001990

Bachelor of Computer Science (Information Systems)

SUPERVISOR

**Dr. Fairuz Amalina Narudin**

FYP Monitoring Presentation · Tentative title

# One file builds the cloud, and its mistakes.

1. Cloud infrastructure is now written as code: Terraform files declare AWS resources before they exist.
2. A mistake in the file is deployed every time it is applied, and scanners usually report each mistake on its own.
3. This project analyses selected Terraform before deployment and explains how weaknesses connect.

| | |
|---|---|
| **Detect** | What is misconfigured? |
| **Explain** | Why is it risky? |
| **Connect** | How can weaknesses connect? |
| **Prioritise** | What should be fixed first? |

Terraform documentation · developer.hashicorp.com ↗

main.tf · the file Checkov scans on slide 6 — open file

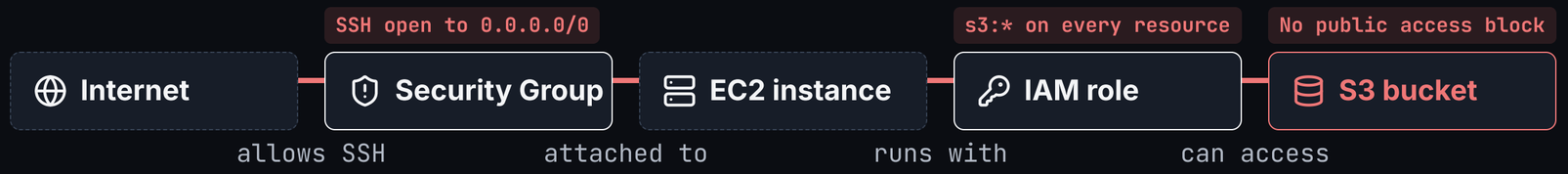
```
1  resource "aws_security_group" "web" {
2    ingress {
3      from_port   = 22
4      to_port     = 22
5      protocol    = "tcp"
6      cidr_blocks = ["0.0.0.0/0"]
7    }
8  }
9
10 resource "aws_instance" "app" {
11   ami                    = "ami-12345678"
12   instance_type          = "t3.micro"
13   vpc_security_group_ids = [aws_security_group.web.id]
14   iam_instance_profile   = aws_iam_instance_profile.app.name
15 }
16
17 resource "aws_iam_instance_profile" "app" {
18   role = aws_iam_role.app.name
19 }
20
21 resource "aws_iam_role" "app" {
22   assume_role_policy = jsonencode({ Statement = [{ Action = "sts:AssumeRole",
23     Effect = "Allow", Principal = { Service = "ec2.amazonaws.com" } }] })
24 }
25
26 resource "aws_iam_role_policy" "app" {
27   role   = aws_iam_role.app.id
28   policy = jsonencode({ Statement = [{
29     Effect = "Allow", Action = "s3:*", Resource = "*"
30   }] })
31 }
32
33 resource "aws_s3_bucket" "records" {
34   bucket = "app-records"
35 }
```

**SSH open to the whole internet**
`aws_security_group.web`
**Why** Port 22 accepts connections from any IPv4 address (0.0.0.0/0).
**Fix** Restrict cidr_blocks to a trusted range, or use managed access instead of SSH.

**Role can do anything in S3**
`aws_iam_role_policy.app`
**Why** Action "s3:*" on Resource "*" grants every S3 action on every bucket.
**Fix** Scope Action and Resource to the specific bucket and operations the app needs.

**Bucket has no public access block**
`aws_s3_bucket.records`
**Why** Nothing in the configuration prevents the bucket from being made public later.
**Fix** Add aws_s3_bucket_public_access_block with all four settings enabled.

# Three findings. *One* potential path.




Connected: each link must be proven from the configuration. Only then is it one combined potential risk.

## Detect

PS1 Detected weaknesses stay unconnected

**Limited contextual analysis of interconnected IaC configurations**

Rule-based IaC scanners detect known patterns, but coverage depends on the rules implemented. Individual findings may not show how resources, identities and permissions interact to form a broader risk.

## Understand

PS2 The reader must work out why it matters

**Limited explainability of interconnected security findings**

A finding may name a weakness, yet the reader still has to work out the evidence, the wider implication and how related configurations contribute to the risk.

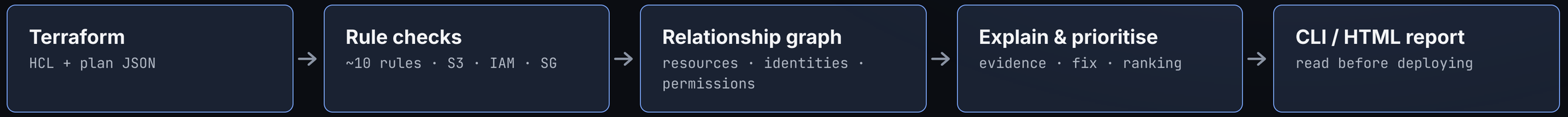
## Prioritise

PS3 Combined risk is not ranked as one

**Limited contextual prioritisation of combined cloud security risks**

The same weakness can matter more or less depending on surrounding resources and permissions. Scoring weaknesses independently may not communicate combined risk.

# Four objectives, one analyzer.




## 01 Detect selected misconfigurations in Terraform

To identify and analyse selected AWS cloud misconfigurations in Terraform Infrastructure as Code using a rule-based assessment approach.

Answers PS1

## 02 Model relationships to find potential attack paths

To develop context-aware analysis that models relationships between selected AWS resources, identities and permissions to identify potential attack paths.

Answers PS1

## 03 Explain with evidence, then prioritise

To develop an explainable risk assessment approach that provides evidence-linked findings, remediation guidance and contextual risk prioritisation.

Answers PS2 · PS3

## 04 Evaluate on labelled scenarios against Checkov

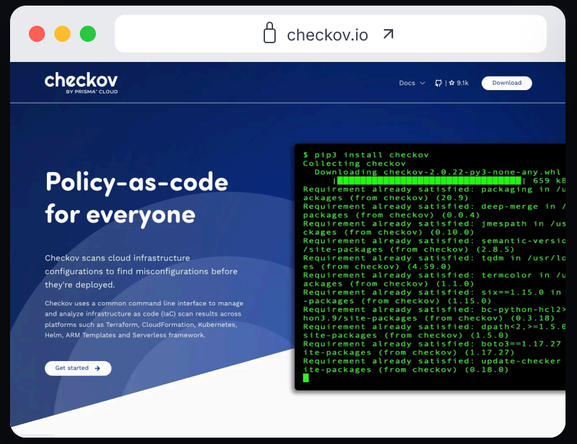
To evaluate the proposed analyzer using labelled Terraform test scenarios, comparison with an existing IaC security scanner, and optional read-only validation against selected live AWS configurations.

8–10 labelled Terraform scenarios: ≥3 clean, 2 tricky-but-safe, ≥2 attack-path chains

Compared with Checkov on shared checks: precision, recall, F1

Optional: read-only Boto3 check of an owned sandbox account; nothing is changed

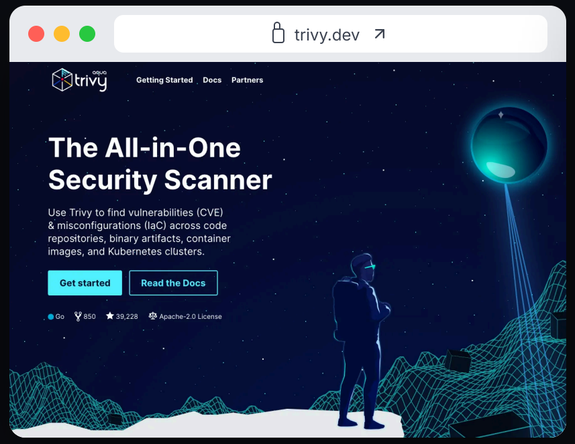
# What already exists, and where this project fits.




## Checkov

Scans Terraform and other IaC before deployment with built-in policies.

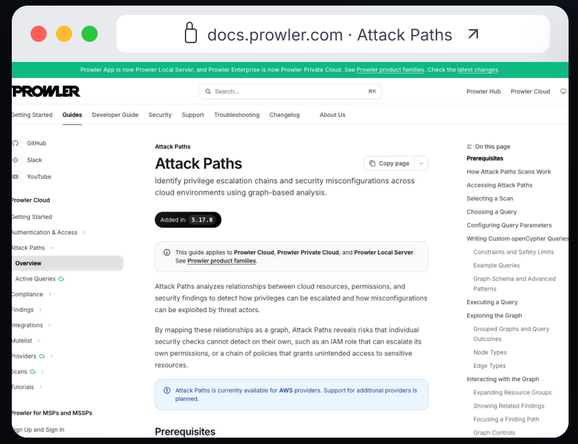
**Differs:** This project focuses on a small set of explained, ranked paths, measured against Checkov.




## Trivy

Finds vulnerabilities, misconfigurations (including IaC) and secrets.

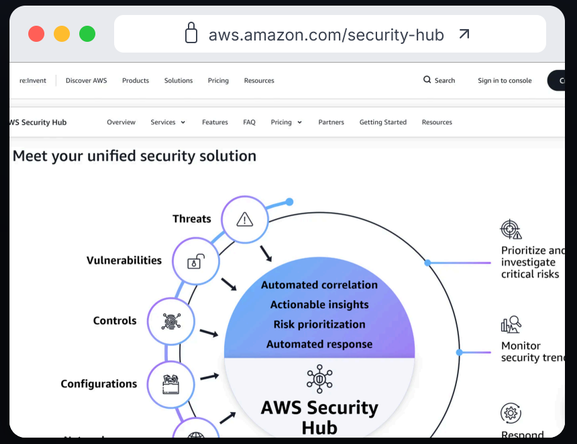
**Differs:** Relationship analysis was not covered in the sources reviewed; this project centres on it.




## Prowler

Assesses deployed cloud accounts; Prowler App draws graph-based Attack Paths for AWS.

**Differs:** Works on a running account; this project works on Terraform before deployment.




## AWS Security Hub

AWS's unified security service: correlates threats, vulnerabilities and configurations, and prioritises critical risks in AWS accounts.

**Differs:** Requires deployed resources; this project reviews the configuration first.



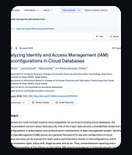
Movva, D. K., Pullikallu, A. R., & Sugasi, M. K. (2025). Infrastructure-as-Code Security and Drift Detection Using LLMs.

Reports 31% higher detection of context-dependent misconfigurations in its own evaluation: context matters.



Keerthana, K. S. (2026). Static Analysis and LLM-Based Review for Terraform Security and Cost Issues: An Exploratory Comparative Study.

Contrasts deterministic checks with contextual explanation and suggested fixes.



Almarri, A., Alawadh, A., Alsayed, M., & Rafique, M. A. (2026). Analyzing Identity and Access Management (IAM) Misconfigurations in Cloud Databases.

Excessive rights and manual policy administration lead to privilege escalation: IAM belongs in scope.

**Direction** Terraform detection + relationships + evidence + prioritisation: a focused combination, measured against Checkov.

# From separate findings to one explained path.

## 1 Today: real scanner output

```
$ checkov -f main.tf --compact --fra…   main.tf  full output

Passed checks: 22, Failed checks: 17, Skipped checks: 0

Check: CKV_AWS_24: "Ensure no security groups allow ingress from 0.0.0.0:0 to port 22"
FAILED for resource: aws_security_group.web

Check: CKV_AWS_355: "Ensure no IAM policies documents allow "*" as a statement's resource for restrictable actions"
FAILED for resource: aws_iam_role_policy.app

Check: CKV_AWS_288: "Ensure IAM policies does not allow data exfiltration"
FAILED for resource: aws_iam_role_policy.app

Check: CKV2_AWS_6: "Ensure that S3 bucket has a Public Access block"
FAILED for resource: aws_s3_bucket.records

… and 13 other failed checks, listed one by one
```

Real output from Checkov 3.3.29 on the main.tf from slide 2, 11 Nov 2026. The findings are right, but each is reported on its own.

## 2 The analyzer connects them

**Internet** — 0.0.0.0/0

allows SSH from

```
cidr_blocks = ["0.0.0.0/0"], port 22 (main.tf:3-6)
```

**Security Group** — aws_security_group.web

attached to

```
vpc_security_group_ids = [aws_security_group.web.id] (main.tf:13)
```

**EC2 instance** — aws_instance.app

runs with role

```
iam_instance_profile → aws_iam_instance_profile.app (role = aws_iam_role.app.name)
```

**IAM role** — aws_iam_role.app

can access

```
aws_iam_role_policy.app (role = aws_iam_role.app.id): Action = "s3:*", Resource = "*"
```

**S3 bucket** — aws_s3_bucket.records

## 3 What it would report

cloud-risk-analyzer · report.html — Planned mock-up

#1 · COMBINED RISK

### Potential attack path: Internet → S3 bucket

Internet → Security Group → EC2 → IAM role → S3 bucket

WHY

An internet-reachable instance runs with a role that can read and write every S3 bucket, including app-records.

EVIDENCE

4 links, each tied to a line of main.tf

PRIORITY

Ranked above its four individual findings, as one combined risk.

FIX

Break any one link: restrict SSH, detach the role, or scope the policy to the bucket it needs.

A potential path built from configuration evidence, not a confirmed exploit.

# A community collaborator, and who else shapes the work.

COLLABORATOR · CONFIRMED

## Lejiend Community

lejiend.com/community ↗ Community owner · Lejiend ↗

INPUT SOUGHT FROM THE COMMUNITY

- Practitioner feedback on the Terraform test scenarios
- Review of whether the attack-path explanations are clear
- A channel to reach cloud and technology practitioners

HOW IT IMPROVES THE PROJECT

Scenarios and explanations shaped by people who use cloud infrastructure, not only by the author.

SUPERVISOR

### Dr. Fairuz Amalina Narudin

FYP supervisor · academic guidance

**Input sought** Scope, rule selection, evaluation design

CONTACTED

### Farhan Helmy

AI & full-stack engineer (as described on his site)

**Input sought** Technical feedback on the analyzer and its report

farhanhelmy.com ↗ LinkedIn ↗

POTENTIAL

### Wider cloud security practitioners

Industry perspectives

**Input sought** Common AWS misconfiguration patterns

**Confirmed** agreed role **Contacted** asked, response pending **Planned** outreach planned **Potential** identified only

# Detect → Connect → Explain → Prioritise

selected misconfigurations in Terraform → resources, identities and permissions → evidence and remediation → combined risk first

## From configuration findings to *contextual* cloud security understanding.

Thank you. Questions?


REFERENCES

Movva, D. K., Pullikallu, A. R., & Sugasi, M. K. (2025). Infrastructure-as-Code Security and Drift Detection Using LLMs. *International Journal of Computer Security, 2(1), 9–25*. https://doi.org/10.34218/IJCST_02_01_002

Keerthana, K. S. (2026). Static Analysis and LLM-Based Review for Terraform Security and Cost Issues: An Exploratory Comparative Study. *International Journal of Engineering Applied Sciences and Technology, 11(5), 95–99*. https://doi.org/10.33564/IJEAST.2026.v11i05.010

Almarri, A., Alawadh, A., Alsayed, M., & Rafique, M. A. (2026). Analyzing Identity and Access Management (IAM) Misconfigurations in Cloud Databases. *Computers, 15(7), 409*. https://doi.org/10.3390/computers15070409

TOOLS, DOCUMENTATION & STANDARDS

Checkov · YAML custom policies (connection state)

Trivy · misconfiguration scanning

Prowler · Attack Paths

AWS Security Hub · potential attack path graph

Terraform documentation · JSON output format

CIS Amazon Web Services Foundations Benchmark v7.0.0

Lejiend Community (collaborator · community owner: linkedin.com/in/lejiend)

Screenshots of official pages captured 11 Nov 2026 for academic reference.